UNIT-II

Footprinting and Scanning

- Footprinting involves both passive and active information gathering, such as reviewing a company's website (passive) and social engineering through calls (active).
- Scanning includes pinging machines, determining network ranges, and port scanning.
- The EC-Council outlines seven steps:
  - **Information gathering**
  - **Determining network range**
  - **Identifying active machines**
  - **Finding open ports/access points**
  - **OS fingerprinting**
  - **Fingerprinting services**
  - **Mapping the network attack surface**
- Ethical hacking is a process of discovery and may not always follow these steps in order.

Outline

- Information Gathering
- Determining the Network Range
- Identifying Active Machines
- Finding Open Ports and Access Points
- OS Fingerprinting Services
- Mapping the Network Attack Surface

Information Gathering

Information Gathering

- The information-gathering steps of footprinting and scanning are crucial for a successful penetration test, as they can significantly impact its effectiveness.
- A wealth of information about organizations is available from their websites, trade papers, Usenet, financial databases, or disgruntled employees.

Information Gathering : Documentation

- Effective information gathering involves thorough documentation.
- To start, create a systematic method to profile a target and record results in a matrix.
- This matrix should include fields for domain names, IP addresses, DNS servers, employee information, email addresses, IP address ranges, open ports, and banner details.
- Building this information early helps in mapping the network and planning the best attack method.

Information Gathering : Documentation

	A	B	C	D	E
1	**Obtained Thru Search Engine**	**Results**	**Social Network Sites**	**Results**	**Website Footprinting**
2	Employees		Profile		OS's
3	Login pages		News		Scripting
4	Portal URL's		Education		Job requests
5	Technologies		Family		Other
6	**Email Footprinting**	**Results**	**People Search Sites**	**Results**	**Google Hacking**
7	IP address		Date of birth		Files containing passwords
8	Email Address		Email		Error messages
9	Geo location		Photos		Other findings
10	**Whois Footprinting**	**Results**	**Network footprinting**	**Results**	**DNS footprinting**
11	Domain name		Network range		DNS servers
12	Contact details		Subnet mask		Zone transfer (Y/N)
13	Domain creation date		Traceroute findings		Types of Servers
14	Hosting company		Other data		DNSSEC (Y/N)

Figure 3-1 Documentation Finding

Information Gathering : The Organization's Website

- To get started with the initial documentation for an organization, begin by searching for the company's website using a search engine like Google, Bing, or Yahoo!. Look for the following:
  - **Company URL**: The main domain name of the company.
  - **Internal URLs**: Subdomains or specific sections of the site, such as support.Dell.com for Dell.
  - **Restricted URLs**: Domains or subdomains that are not accessible to the public.
  - **Internal Pages**: Pages containing company news, employment opportunities, addresses, and phone numbers.
- The goal is to gather all open-source information freely provided to clients, customers, or the public.

Information Gathering : The Organization's Website : Example (local web hosting company)

- ***A local web hosting company's website*** reveals a news and updates section indicating:
  - **Server Updates**: Servers updated to Plesk 10.0.1. Users log in using their domain names, with passwords transferred from old servers.
  - **Network Equipment**: Transition from Cisco to Extreme Networks, adding a third Internet connection for higher fault tolerance.
- **Risks**:
  - Attackers can identify the infrastructure and plan DoS attacks knowing they need to target three nodes.
  - Competitors gain insights into the company's systems.

Information Gathering : The Organization's Website : Example (local web hosting company)

- **Additional Information Gathering**:
  - **Wayback Machine**: Useful for accessing archived web pages.
  - **Company Directories**: Key employees' details can be exploited via social engineering.
  - **Email Bounces**: Sending emails to invalid addresses can reveal email server IP and version.
  - **Physical Information**: Tools like Bing Maps and Google Earth help identify the physical layout, entry points, and landmarks.
- **Pen Test Note**: Record all findings and alert the organization to potential vulnerabilities.

Information Gathering : Job Boards

- When examining a company's job posting board or major Internet job boards like CareerBuilder, Monster, Dice, and Indeed, you can find valuable information. Here's what to look for and how it can be useful:
- **Example Information from Job Listings**:
  - **Responsibilities**: Management of Windows 2008 Active Directory, MS Exchange 2008, SQL 2008, Citrix.
  - **Interaction**: Work with technical support to resolve issues and maintain security updates.
  - **Experience**: Active Directory, Microsoft Clustering, Network Load Balancing, MS Exchange 2007, MS SQL 2003, Citrix MetaFrame XP, EMC CX-400 SAN, Veritas Net Backup, BigBrother, NetIQ Monitoring SW.
  - **Tasks**: Maintain, support, and troubleshoot a Windows 7 LAN.
- **Risks**:
  - Job postings can reveal critical details about the company's network infrastructure and systems, which can be exploited by attackers.
- **Mitigation**:
  - Reduce system-specific details in job postings.
  - Use company confidential postings to conceal the company's identity.

Information Gathering : Employee and People Searches

- Security involves more than just technical and physical controls; it also encompasses people.
- Ethical hackers should gather information about key personnel, as such data can be crucial for an attacker.
- Sources include websites, employee directories, press releases, and third-party sites, which can be categorized into data aggregation brokers and social networking sites.
- **Data Aggregation Brokerage Sites**:
  - **Pipl**: https://pipl.com/
  - **Spokeo**: http://www.spokeo.com/
  - **BirthdayDatabase.com**: http://www.birthdatabase.com/
  - **Whitepages**: http://www.whitepages.com/
  - **People Search Now**: http://www.peoplesearchnow.com/
  - **Peoplefinders**: http://www.peoplefinders.com/
- These sites enable attackers to locate key individuals, identify home phone numbers, and even create maps to their houses.

Information Gathering : Employee and People Searches

- Social networking sites are significant targets for attackers due to their open nature and users' lack of security awareness.
- These platforms facilitate communication and marketing but pose considerable security risks.
- Users often overlook security, and these sites prioritize connectivity over security.
- Ethical hackers should check the following sites:
  - **Facebook**
  - **Twitter**
  - **LinkedIn**
  - **Google+**
  - **Pinterest**
- These sites can provide valuable information about individuals, making them potential security vulnerabilities.

Information Gathering : EDGAR Database

- For publicly traded organizations, reviewing the SEC's EDGAR database is crucial.
- This database, found at https://www.sec.gov/edgar/searchedgar/companysearch.html, contains extensive information, particularly the 10-Q and 10-K reports.
- These documents provide yearly and quarterly reports, including earnings, revenue, acquisitions, and mergers.
- **Key Points to Investigate**:
  - Different entity names from the parent organization could indicate integration points between networks.
  - This information can help identify ways to access the more secure parent company from a subsidiary.
- **Additional Financial Information Sources**:
  - **Marketwatch**: http://www.marketwatch.com
  - **Experian**: http://www.experian.com
  - **Wall Street Consensus Monitor**: http://www.wallstreetconsensusmonitor.com/
  - **Euromonitor**: http://www.euromonitor.com
- Record all findings and use them for further research in databases like IANA and ARIN.

Information Gathering : Google hacking

- Search engines like Google offer far more powerful search capabilities than most people realize.
- Beyond simple searches, Google can translate documents, perform news searches, image searches, and be used for "Google hacking."
- This involves using advanced search techniques to find vulnerabilities.

Information Gathering : Google hacking

- Google Advanced Operators:
  - **Usage:** Combining basic search techniques with advanced operators allows for specific and refined queries, making Google a powerful tool for finding vulnerabilities.
  - **Examples:**
    - site:example.com inurl:admin
    - intitle:"index of" "parent directory"
- By understanding and utilizing these advanced search techniques, one can identify potential security weaknesses and protect against unauthorized access.

Information Gathering : Registrar Query

- In the past, obtaining domain name information was simpler due to fewer sources and less restrictive policies.
- However, the rise of spammers and hackers has led to tighter controls.
- Today, the management of domain names and IP addresses is overseen by various organizations:

Information Gathering : Registrar Query

- **ICANN**:
  - **Role**: The Internet Corporation for Assigned Names and Numbers (ICANN) manages IP address space allocation, protocol parameter assignments, and domain name system management.
  - **Function**: ICANN oversees the overall management but delegates domain name registration to multiple competing firms.
- **Domain Name Registrars**:
  - **Examples**:
    - **Network Solutions**: https://networksolutions.com
    - **Register.com**: https://www.register.com
    - **GoDaddy**: https://godaddy.com
    - **Tucows**: http://www.tucows.com
- **Regional Internet Registries (RIRs)**:
  - **Role**: RIRs manage, distribute, and register public IP addresses within specific regions.

Information Gathering : Registrar Query

Table 3-3 RIRs and Their Area of Control

RIR	Region of Control
ARIN	North and South America and sub-Saharan Africa
APNIC	Asia and Pacific
RIPE	Europe, Middle East, and parts of Africa
LACNIC	Latin America and the Caribbean
AfriNIC	Planned RIR to support Africa

Information Gathering : Registrar Query : Whois

- Purpose:
  - Whois is a utility that queries the Internet domain name administration system, returning details about a specified domain name, such as domain ownership, address, location, phone number, and more.
- Usage:
  - Primary Tool: Used to navigate databases and gather information from the Domain Name System (DNS).
- Platform-Specific Details:
  - **Linux**:
    - Built-in utility.
    - **Usage**: From the Linux prompt, type *whois domainname.com* or *whois?* to see various options.
  - **Windows**:
    - No built-in Whois client.
    - Users must use a third-party tool or website to obtain Whois information.
- This tool is essential for gathering domain-related information and is especially convenient for Linux users due to its built-in nature.

Information Gathering : Registrar Query : Whois

following listing shows the results after www.domaintools.com/ is queried for information about www.pearson.com:

```
Registrant:
      Pearson PLC
      Clive Carmock
      80 Strand London
      London, UK WC2R 0RL
      GB
      Email:

   Registrar Name....: CORPORATE DOMAINS, INC.
   Registrar Whois...: whois.corporatedomains.com
   Registrar Homepage: www.cscprotectsbrands.com

   Domain Name: pearson.com

      Created on..............: Mon, Nov 25, 1996
      Expires on..............: Thu, Nov 24, 2022
      Record last updated on..: Thu, Aug 08, 2016

   Administrative Contact:
      Pearson PLC
      Clive Carmock
      80 Strand London
      ., . WC2R 0RL
      GB
      Phone: 044-2070-105580
      Email:
```

```
Technical Contact:
   Pearson PLC
   Clive Carmock
   80 Strand London
   ., . WC2R 0RL
   GB
   Phone: 044-2070-105580
   Email:

DNS Servers:
usrxdns1.pearsontc.com
oldtxdns2.pearsontc.com
ns.pearson.com
ns2.pearson.com
```

Information Gathering : DNS Enumeration

- If all the previous information has been acquired, the DNS might be targeted for zone transfers.
- Zone Transfer:
  - Definition: A zone transfer updates DNS servers by transferring database contents, ensuring all servers have the latest information.
  - Structure: DNS requests move up a hierarchical structure until a resolving DNS server is found.

Information Gathering : DNS Enumeration

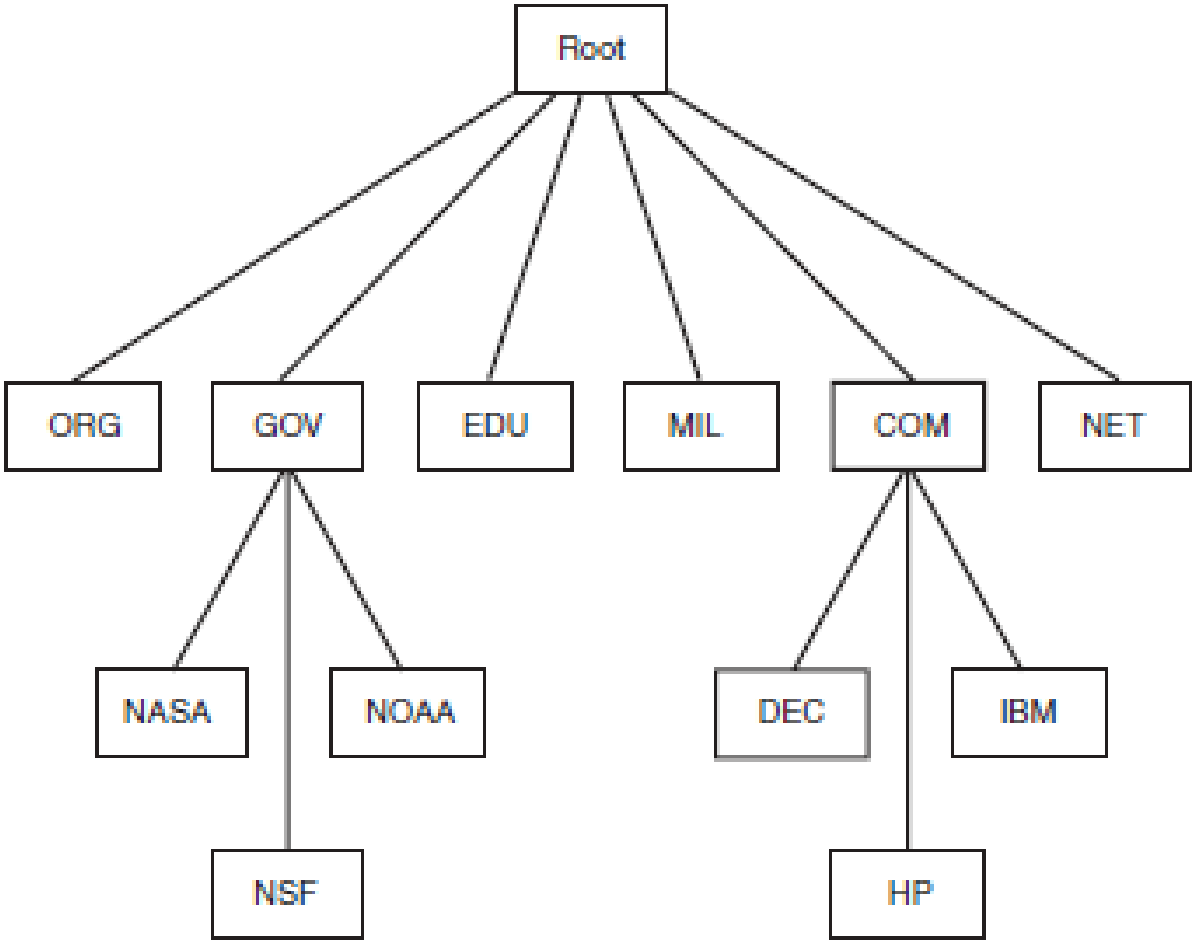

Figure 3-6 DNS Structure

Information Gathering : DNS Enumeration

- Tool for Querying DNS Servers: Nslookup:
  - **Function**: Queries DNS servers for machine name and address information.
  - **Availability**: Both Linux and Windows systems have Nslookup clients.
  - **Usage**:
    - Open the command line.
    - Type nslookup followed by an IP address or machine name.
    - Nslookup returns the name, known IP addresses, and CNAMEs for the identified machine.
- Example:
  - To find the IP addresses of Google's web servers:
    - Open command line.
    - Type nslookup google.com.
    - Review the returned IP addresses and CNAMEs.
- Using Nslookup effectively allows you to gather detailed DNS information, providing insights into the network infrastructure of the target organization.

Information Gathering : DNS Enumeration

```
┌──(kali㉿kali)-[~]
└─$ nslookup www.google.com
Server:         172.31.0.2
Address:        172.31.0.2#53

Non-authoritative answer:
Name:   www.google.com
Address: 142.251.42.100
Name:   www.google.com
Address: 2404:6800:4009:81b::2004


┌──(kali㉿kali)-[~]
└─$ nslookup www.facebook.com
Server:         172.31.0.2
Address:        172.31.0.2#53

Non-authoritative answer:
www.facebook.com        canonical name = star-mini.c10r.facebook.com.
Name:   star-mini.c10r.facebook.com
Address: 157.240.16.35
Name:   star-mini.c10r.facebook.com
Address: 2a03:2880:f33e:8:face:b00c:0:25de


┌──(kali㉿kali)-[~]
└─$ nslookup www.microsoft.com
Server:         172.31.0.2
Address:        172.31.0.2#53

Non-authoritative answer:
www.microsoft.com       canonical name = www.microsoft.com-c-3.edgekey.net.
www.microsoft.com-c-3.edgekey.net       canonical name = www.microsoft.com-c-3.edgekey.net.globalredir.akadns.net.
www.microsoft.com-c-3.edgekey.net.globalredir.akadns.net        canonical name = e13678.dscb.akamaiedge.net.
Name:   e13678.dscb.akamaiedge.net
Address: 104.91.33.167
Name:   e13678.dscb.akamaiedge.net
Address: 2600:1417:75:cb8::356e
Name:   e13678.dscb.akamaiedge.net
Address: 2600:1417:75:cb9::356e
```

Information Gathering : DNS Enumeration

Table 3-4 IPv4 DNS Records and Types

Record Name	Record Type	Purpose
Host	A	Maps a domain name to an IPv4 address
Host	AAAA	Maps a domain name to an IPv6 address
Pointer	PTR	Maps an IP address to a domain name
Name Server	NS	Specifies the servers that provide DNS services
Start of Authority	SOA	Configures settings for zone transfers and record caching
Service Locator	SRV	Used to locate services in the network
Mail	MX	Used to identify SMTP servers

Information Gathering : DNS Enumeration : Zone Transfer

- DNS zone transfers update DNS information from a primary to a secondary name server through a four-step process, like DHCP.
  - Steps of DNS Zone Transfers:
    - Initiate Request:
      - The secondary name server starts the process by requesting the Start of Authority (SOA) record from the primary name server.
    - Authorization Check:
      - The primary name server checks its list of authorized servers. If the secondary server is authorized, the SOA record is sent to the secondary server.
    - SOA Record Comparison:
      - The secondary server compares the received SOA record with its existing one.
      - If the SOA records match, no update is needed, and the process stops.
      - If the SOA record has a higher serial number, indicating changes since the last synchronization, the secondary server requires an update.
    - AXFR Request and Zone Transfer:
      - The secondary server sends an All-Zone Transfer (AXFR) request to the primary server.
      - Upon receiving the AXFR request, the primary server sends the entire zone file to the secondary server.
- This process ensures that secondary DNS servers stay up-to-date with the primary server, maintaining consistent and accurate DNS information across the network.

Information Gathering : DNS Enumeration : Zone Transfer

dig axfr @nsztm1.digi.ninja zonetransfer.me

```
└─$ dig axfr @nsztm1.digi.ninja zonetransfer.me

; <<>> DiG 9.20.0-Debian <<>> axfr @nsztm1.digi.ninja zonetransfer.me
; (1 server found)
;; global options: +cmd
zonetransfer.me.        7200    IN      SOA     nsztm1.digi.ninja. robin.digi.ninja. 2019100801 172800 900 1209600 3600
zonetransfer.me.        300     IN      HINFO   "Casio fx-700G" "Windows XP"
zonetransfer.me.        301     IN      TXT     "google-site-verification=tyP28J7JAUHA9fw2sHXMgcCC0I6XBmmoVi04VlMewxA"
zonetransfer.me.        7200    IN      MX      0 ASPMX.L.GOOGLE.COM.
zonetransfer.me.        7200    IN      MX      10 ALT1.ASPMX.L.GOOGLE.COM.
zonetransfer.me.        7200    IN      MX      10 ALT2.ASPMX.L.GOOGLE.COM.
zonetransfer.me.        7200    IN      MX      20 ASPMX2.GOOGLEMAIL.COM.
zonetransfer.me.        7200    IN      MX      20 ASPMX3.GOOGLEMAIL.COM.
zonetransfer.me.        7200    IN      MX      20 ASPMX4.GOOGLEMAIL.COM.
zonetransfer.me.        7200    IN      MX      20 ASPMX5.GOOGLEMAIL.COM.
zonetransfer.me.        7200    IN      A       5.196.105.14
zonetransfer.me.        7200    IN      NS      nsztm1.digi.ninja.
zonetransfer.me.        7200    IN      NS      nsztm2.digi.ninja.
_acme-challenge.zonetransfer.me. 301 IN TXT     "6Oa05hbUJ9xSsvYy7pApQvwCUSSGgxvrbdizjePEsZI"
_sip._tcp.zonetransfer.me. 14000 IN     SRV     0 0 5060 www.zonetransfer.me.
14.105.196.5.IN-ADDR.ARPA.zonetransfer.me. 7200 IN PTR www.zonetransfer.me.
asfdbauthdns.zonetransfer.me. 7900 IN   AFSDB   1 asfdbbox.zonetransfer.me.
asfdbbox.zonetransfer.me. 7200  IN      A       127.0.0.1
asfdbvolume.zonetransfer.me. 7800 IN    AFSDB   1 asfdbbox.zonetransfer.me.
canberra-office.zonetransfer.me. 7200 IN A      202.14.81.230
cmdexec.zonetransfer.me. 300    IN      TXT     "; ls"
contact.zonetransfer.me. 2592000 IN     TXT     "Remember to call or email Pippa on +44 123 4567890 or pippa@zonetransfer.me when making DNS changes"
dc-office.zonetransfer.me. 7200 IN      A       143.228.181.132
deadbeef.zonetransfer.me. 7201  IN      AAAA    dead:beaf::
dr.zonetransfer.me.     300     IN      LOC     53 20 56.558 N 1 38 33.526 W 0.00m 1m 10000m 10m
DZC.zonetransfer.me.    7200    IN      TXT     "AbCdEfG"
email.zonetransfer.me.  2222    IN      NAPTR   1 1 "P" "E2U+email" "" email.zonetransfer.me.zonetransfer.me.
email.zonetransfer.me.  7200    IN      A       74.125.206.26
Hello.zonetransfer.me.  7200    IN      TXT     "Hi to Josh and all his class"
home.zonetransfer.me.   7200    IN      A       127.0.0.1
Info.zonetransfer.me.   7200    IN      TXT     "ZoneTransfer.me service provided by Robin Wood - robin@digi.ninja. See http://digi.ninja/projects/zonetrans
ferme.php for more information."
internal.zonetransfer.me. 300   IN      NS      intns2.zonetransfer.me.
intns1.zonetransfer.me. 300     IN      A       81.4.108.41
intns2.zonetransfer.me. 300     IN      A       167.88.42.94
office.zonetransfer.me. 7200    IN      A       4.23.39.254
ipv6actnow.org.zonetransfer.me. 7200 IN AAAA    2001:67c:2e8:11::c100:1332
owa.zonetransfer.me.    7200    IN      A       207.46.197.32
robinwood.zonetransfer.me. 302  IN      TXT     "Robin Wood"
rp.zonetransfer.me.     321     IN      RP      robin.zonetransfer.me. robinwood.zonetransfer.me.
sip.zonetransfer.me.    3333    IN      NAPTR   2 3 "P" "E2U+sip" "!^.*$!sip:customer-service@zonetransfer.me!" .
sqli.zonetransfer.me.   300     IN      TXT     "' or 1=1 --"
sshock.zonetransfer.me. 7200    IN      TXT     "() { :]}; echo ShellShocked"
staging.zonetransfer.me. 7200   IN      CNAME   www.sydneyoperahouse.com.
alltcpportsopen.firewall.test.zonetransfer.me. 301 IN A 127.0.0.1
testing.zonetransfer.me. 301    IN      CNAME   www.zonetransfer.me.
vpn.zonetransfer.me.    4000    IN      A       174.36.59.154
www.zonetransfer.me.    7200    IN      A       5.196.105.14
xss.zonetransfer.me.    300     IN      TXT     "'><script>alert('Boo')</script>"
zonetransfer.me.        7200    IN      SOA     nsztm1.digi.ninja. robin.digi.ninja. 2019100801 172800 900 1209600 3600
;; Query time: 128 msec
;; SERVER: 81.4.108.41#53(nsztm1.digi.ninja) (TCP)
;; WHEN: Sun Aug 04 16:31:30 UTC 2024
;; XFR size: 50 records (messages 1, bytes 2085)
```

Determining Network Range

Determining Network Range

- When performing a penetration test, it's essential to determine the range of IP addresses available for scanning and further enumeration. This can be achieved by using the **ARIN (American Registry for Internet Numbers)** Whois lookup.
- Here's how you can do it:
  1. **Identify an IP Address**: Use an IP address discovered during your initial recon
  2. **Perform Whois Lookup**: Go to ARIN Whois and enter the IP address.
  3. **Review the Information**: The Whois lookup will provide detailed information about the network range associated with the IP address. For example, entering 192.17.170.17 into the ARIN Whois might reveal the network range assigned to that IP, along with other details.
- **Example Output:**
  - **IP Address**: 192.17.170.17
  - **Organization**: Example Org
  - **Network Range**: 192.17.170.0 - 192.17.170.255
  - **Other Details**: Names, addresses, phone numbers, server names, and additional IP ranges.
- This information helps to map out the scope of the network you are testing, allowing for more precise and effective scanning and enumeration.

Determining Network Range : Traceroute

- When using traceroute for network diagnostics, it's important to try different versions and techniques to ensure you get the required results, especially when dealing with firewalls or filtering devices.
- **Techniques for Using Traceroute Effectively:**
  - **Multiple Versions of Traceroute:**
    - **Standard Traceroute**: Uses ICMP (Internet Control Message Protocol) or UDP (User Datagram Protocol).
    - **TCPTraceroute**: Utilizes TCP (Transmission Control Protocol) packets, useful when ICMP and UDP are blocked by the firewall.
  - **Bypassing Firewalls and Filters:**
    - **TCPTraceroute:**
      - Effective when UDP and ICMP are not allowed on the remote gateway.
      - Sends TCP SYN packets, often used on ports like 80 (HTTP) or 443 (HTTPS) to slip past the firewall.
    - **Port-Specific Traceroute**:
      - Developed by Michael Schiffman, a patch called traceroute.diff allows users to specify the port that traceroute will use.
      - Example: Direct traceroute to use UDP port 53, which is typically used for DNS queries. Firewalls often allow traffic on this port, making it a potential method to bypass restrictions..

Identifying Active Machines

Identifying Active Machines

- Attackers use **ping sweeps** to identify active machines before attempting an attack.
- **Ping**, which uses ICMP to send echo requests and receive replies, is common *but often restricted*.
- It's useful for detecting active devices and measuring packet travel speed.
- The ping payload varies by vendor, which can be exploited by hackers using tools like *Loki* and *icmpsend* to embed covert messages in what appear to be normal pings.
- Ping has two main drawbacks:
  - it pings only one system at a time, and not all networks allow it.
  - To check multiple hosts, a ping sweep is used, which scans a range of devices to identify active ones.

Identifying Active Machines

- Tools for performing ping sweeps include:
  - **Angry IP Scanner**: http://angryip.org/
  - **Hping**: http://www.hping.org/
  - **WS_Ping ProPack**: https://ws-ping-propack.en.softonic.com/
  - **SuperScan**: http://www.mcafee.com/us/downloads/free-tools/superscan.aspx
  - **Nmap**: https://nmap.org/

Finding Open Ports and Access Points

Finding Open Ports and Access Points

- Port scanning involves connecting to TCP and UDP ports to identify running services and applications on a target device.
- Once these are discovered, a hacker can determine the best way to attack the system.
- Hackers often focus on the first 1,024 well-known TCP and UDP ports, where most common applications run, instead of scanning all 65,535 ports.
- However, high-order ports, like 31337, are also significant as they can be used by hackers as backdoors.
- TCP is generally easier to scan than UDP due to its connection-oriented nature and the three-way handshake process, which consists of:
  - **Client to Server**: The client sends a TCP packet with the SYN flag and an initial sequence number (ISN).
  - **Server to Client**: The server responds with a packet that has the SYN/ACK flags, acknowledging the client's packet and indicating readiness to communicate.
  - **Client to Server**: The client sends an ACK packet to confirm receipt, and the connection is established, allowing communication to begin.

Finding Open Ports and Access Points

- At the end of a communication session, TCP terminates the connection using a four-step shutdown process:
  - **Client to Server**: The client sends a packet with the FIN/ACK flags set.
  - **Server to Client**: The server responds with a packet that has the ACK flag set to acknowledge the client's packet.
  - **Server to Client**: The server sends another packet with the FIN/ACK flags set, indicating it is also ready to terminate the session.
  - **Client to Server**: The client sends a final packet with the ACK flag set, completing the session termination.
- TCP communication provides robust connections but also opens avenues for hackers to craft packets to elicit server responses or evade intrusion detection systems (IDS).

Finding Open Ports and Access Points

- Nmap and other port-scanning tools exploit these vulnerabilities using various techniques:
  1. **TCP Full Connect scan:** Reliable but easily detectable, it completes a full connection with SYN/ACK from open ports and RST/ACK from closed ones.
  2. **TCP SYN scan:** A stealthy, half-open scan that also gets SYN/ACK from open ports and RST/ACK from closed ones, though most IDSs can now detect it.
  3. **TCP FIN scan:** Sends a FIN packet, expecting no response from open ports and RST/ACK from closed ones, effective mainly on UNIX devices or those compliant with RFC 793.
  4. **TCP NULL scan:** Sends a packet with no flags; open ports send no reply, and closed ports return RST.
  5. **TCP ACK scan:** Identifies ACL rule sets and firewall presence; stateful firewalls return no response, while RST indicates no firewall, and ICMP messages indicate filtered ports.
  6. **TCP XMAS scan:** Uses FIN, URG, and PSH flags; open ports provide no response, and closed ports return RST, effective on systems compliant with RFC 793, common in Linux but not Windows.

Finding Open Ports and Access Points

- Operating systems vary in their application of TCP/IP RFCs, causing some scan types to be ineffective on certain systems, although Full Connect and SYN scans are universally reliable. Other scan techniques, like the idle or zombie scan, help obscure attackers' identities.
- TCP/IP connections use an IP identification number (IPID) for reassembling fragmented traffic.
- TCP's handshake involves a SYN packet from the initiator and a SYN/ACK packet from the receiver if the port is open; closed ports return an RST to indicate termination of communication attempts.
- Unsolicited RSTs are ignored to prevent floods of RSTs between systems.
- An idle scan leverages these behaviors:
  1. The attacker sends an IPID probe to an idle host and gets a response (e.g., IPID 12345).
  2. The attacker sends a spoofed SYN packet to the victim, appearing to come from the idle host.
  3. If the port is open, the victim sends a SYN/ACK, prompting the idle host to respond with an RST, incrementing the IPID (e.g., to 12346).
  4. The attacker sends another probe to the idle host and receives the updated IPID (e.g., 12347).
  5. The IPID increment by two confirms that the port on the victim's system is open.

Finding Open Ports and Access Points

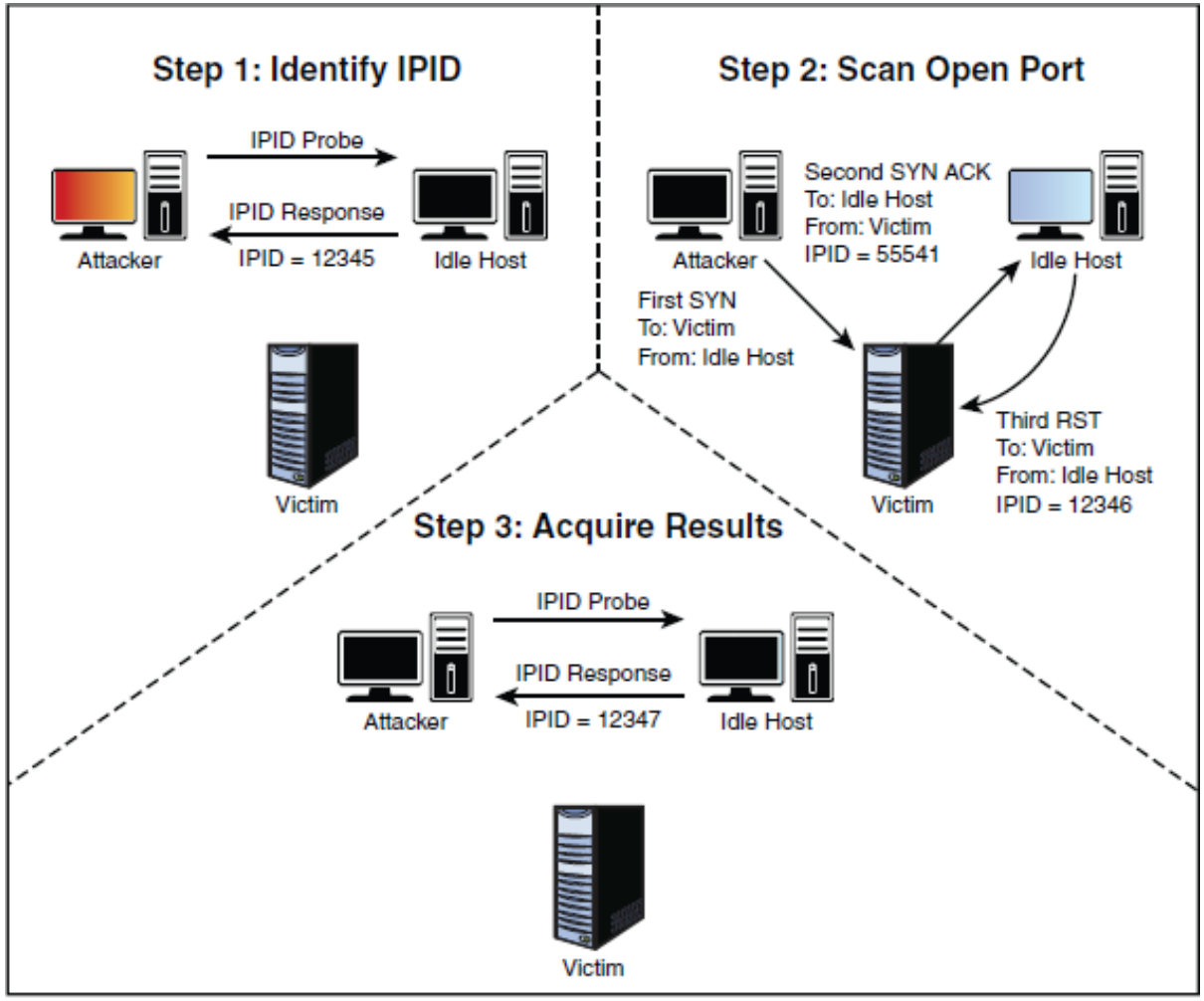

Figure 3-9 IPID Open Port

Finding Open Ports and Access Points

- If the target system's port is closed, the idle scan process proceeds similarly initially:
  1. The attacker sends an IPID probe to the idle host and receives an IPID value (e.g., 12345).
  2. The attacker sends a spoofed SYN packet to the victim, appearing to come from the idle host.
  3. Because the port on the victim's system is closed, it responds with an RST, and no further communication occurs between the victim and the idle host.
  4. The attacker sends another IPID probe to the idle host and receives the updated IPID (e.g., 12346).
- Since the IPID is only incremented by one, the attacker can deduce that the port on the victim's system is closed.

Finding Open Ports and Access Points

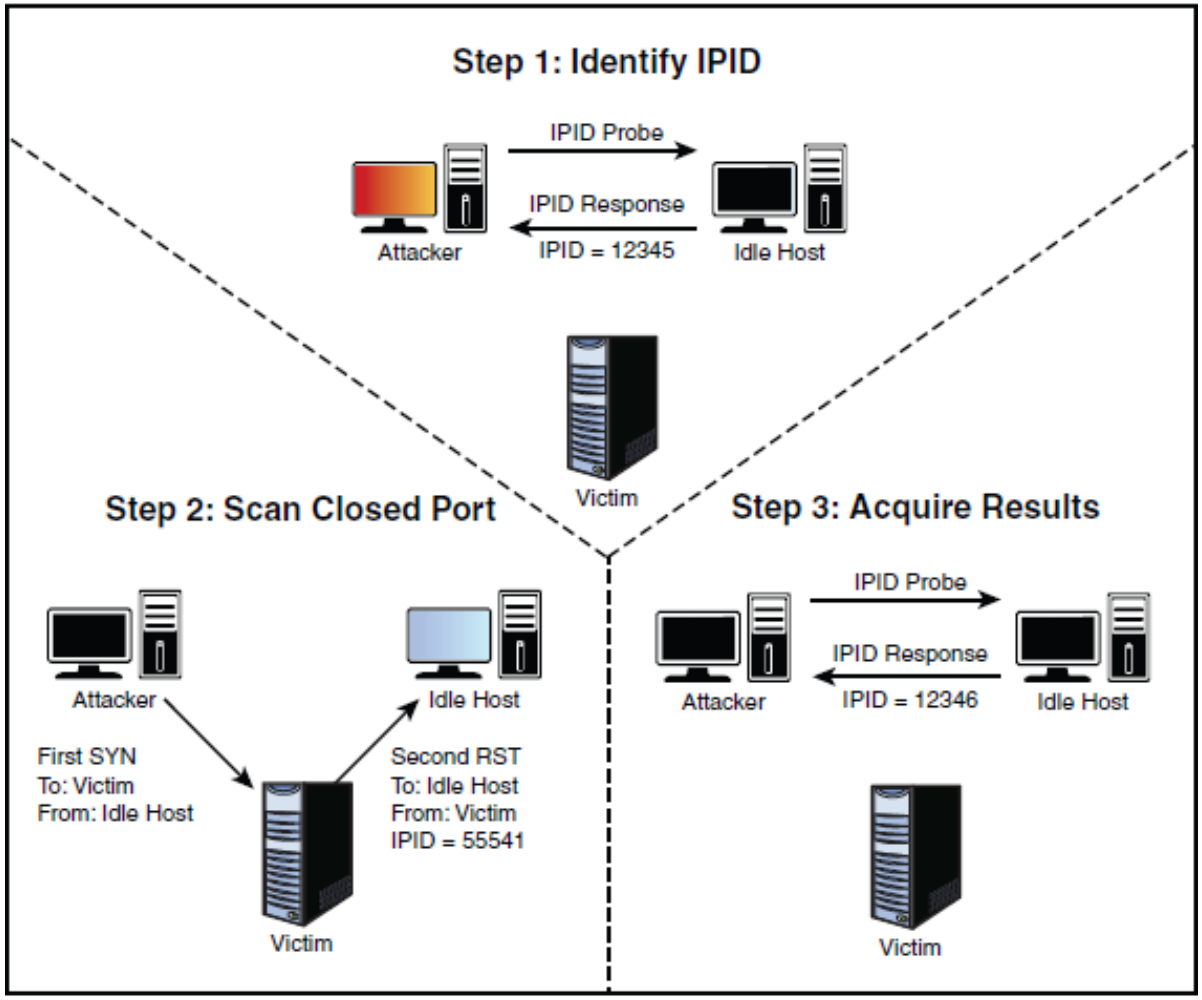

Figure 3-10 IPID Port Closed

Finding Open Ports and Access Points

- While not perfect, idle scanning helps attackers obscure their true address, but it has limitations.
- The idle host must be truly idle to prevent excessive IPID increments, and not all operating systems use incrementing IPIDs.
- For example, some Linux versions set IPID to zero or generate random values, making them unsuitable for this attack. Multiple passes are needed to validate results.
- Other notable scan types include:
  - **ACK scan**: Sends an ACK probe with random sequence numbers. ICMP type 3 code 13 responses may indicate stateless firewalls, while RST can indicate an unfiltered port.
  - **FTP Bounce scan**: Uses an FTP server to obscure the attacker's address.
  - **RPC scan**: Identifies open RPC ports.
  - **Window scan**: Like an ACK scan but examines TCP window size in RST packets to determine open (positive window size) or closed (zero window size) ports.
- UDP scans differ from TCP scans because UDP lacks flags and responses, relying on speed.
- Closed ports might trigger an ICMP type 3 code 3 port unreachable message unless ICMP is blocked, resulting in no response.
- This makes UDP scans yield unreliable results.

Finding Open Ports and Access Points

- Various Port Scanning Tools :
  - Nmap
  - Zenmap
  - SuperScan
  - THC-Amap
  - Hping
  - Etc.

OS Fingerprinting

OS Fingerprinting

- At this point in the information-gathering process, a hacker has identified IP addresses, active systems, and open ports but may not yet know the types of systems involved.
- There are two main methods for identifying targeted devices: passive and active fingerprinting.
- **Passive Fingerprinting:**
  - Relies on sniffing packets and examining characteristics such as IP TTL value, TCP window size, IP DF option, and IP TOS option to determine the operating system (OS).
  - Tools like P0f perform passive fingerprinting without generating additional network traffic.
- **Active Fingerprinting:**
  - Involves sending malformed packets to elicit identifiable responses from the target.
  - Techniques include the FIN probe, bogus flag probe, ISN sampling, IPID sampling, TCP initial window examination, ACK value assessment, TOS tweaking, TCP options probing, and fragmentation handling.
  - Tools like Nmap, which uses the -O option, and Xprobe2, which employs fuzzy signature matching, are popular for active fingerprinting.
  - Active fingerprinting is less stealthy and more likely to be detected by intrusion detection systems (IDS).

OS Fingerprinting

- **Additional Tools:**
  - **Nmap:** Dominant active fingerprinting tool, capable of identifying hundreds of OS types.
  - **Xprobe2:** Uses a mix of TCP, UDP, and ICMP to evade firewalls and IDS.
  - **Winfingerprint:** Windows-based GUI tool that gathers extensive information about Windows servers, including NetBIOS shares, services, users, and more.
- Both passive and active fingerprinting have their advantages and drawbacks. Passive methods are stealthier but less immediate, while active methods are faster but more detectable.

Fingerprinting Services

Fingerprinting Services

- To further gather information and confirm system details, hackers use techniques like banner grabbing on open ports.
- Identifying services running on specific ports can reveal system types and versions, allowing for targeted attacks.
- **Default Ports and Services:**
  - Hackers make educated guesses based on default ports, such as assuming an open port 80 on a Windows 2012 server is running IIS 8.0.
  - Assumptions should be verified since ports and banners can be altered.
- **Finding Open Services:**
  - Tools like Nmap and SuperScan can identify services on open ports.
  - Banner grabbing using Telnet, Netcat, or tools like HTTPrint helps identify software versions by examining responses from specific ports.
  - Example: Using Telnet to connect to port 80 can reveal if a web server is running IIS 6.0.

Fingerprinting Services

- **Additional Tools:**
  - **ID Serve:** Identifies web server software.
  - **NetworkMiner:** Network forensic analysis tool.
  - **Satori:** Network monitoring and analysis.
  - **Netcraft:** Provides site reports including server details.

- **Defense Techniques:**
  - Changing or obscuring banner information can slow attackers.
  - In Linux, disable server signatures in ***httpd.conf***.
  - In Windows, use UrlScan to remove or alter server identity headers.

Mapping the Network Attack Surface

Mapping the Network Attack Surface

- At this point, the hacker has gathered sufficient information to map the network, giving a comprehensive view of the organization's structure.
- Network mapping can be performed manually or with the aid of automated tools.
- **Manual Mapping**
  - **Documentation and Matrix:**
    - Start with a matrix documenting all findings, including:
      - Domain names
      - IP addresses
      - DNS servers
      - Employee information
      - Company location and phone numbers
      - Yearly earnings
      - Recently acquired organizations
      - Email addresses
      - Public IP address range
      - Open ports
      - Wireless access points
      - Modem lines
      - Banner details
- This thorough documentation helps create a detailed blueprint of the target network.

Mapping the Network Attack Surface

- **Automated Mapping**
  - **Tools for Automated Mapping:**
    - Visual Traceroute Programs:
      - SolarWinds Network Topology Mapper: Maps the placement of servers and network devices. More information at SolarWinds.
    - Nmap Scripts:
      - Example command: nmap --traceroute --script traceroute-geolocation.nse -p 80 example.com
      - This command performs a traceroute and provides geolocation data for each hop along the way.
- Automated mapping is generally faster and can be integrated with other tools for more comprehensive results, though it may occasionally produce errors or erroneous results.

Mapping the Network Attack Surface

- **Tools for Tracking and Mapping**
  - **NLog:**
    - Automates and tracks results of Nmap scans.
    - Stores Nmap scan logs in a database, allowing easy search and customizable viewing.
    - Supports extension scripts for different services.
    - More information and download at NLog Project.
  - **CartoReso:**
    - Diagrams a large portion of the network.
    - Uses routines from various tools for OS detection, port scans, service detection, and network mapping using traceroute techniques.
    - Can be run internally for more comprehensive results or from the internet for limited DMZ device contact.
    - More information and download at SourceForge.

Mapping the Network Attack Surface

Summary of Steps: Primary Steps in Network Mapping

1. **Information Gathering:**
   - Collect domain names, IP addresses, DNS servers, and more.
2. **Scanning:**
   - Use tools like Nmap to scan for open ports and services.
3. **Banner Grabbing:**
   - Identify services and software versions.
4. **Manual Documentation:**
   - Create a detailed matrix of all findings.
5. **Automated Mapping:**
   - Use tools like SolarWinds Network Topology Mapper and Nmap scripts.
6. **Result Tracking:**
   - Track and manage results using tools like NLog and CartoReso.

By following these steps and utilizing the described tools, a hacker can efficiently map and understand the target network, preparing for potential attacks.

Table 3-7 The Seven Steps of the Pre-Attack Phase

Step	Title	Active/Passive	Common Tools
One	Information gathering	Passive	www.domaintools.com, ARIN, IANA, Whois, Nslookup
Two	Determining network range	Passive	RIPE, APNIC, LACNIC, ARIN
Three	Identifying active machines	Active	Ping, traceroute, SuperScan, Angry IP Scanner
Four	Finding open ports and access points	Active	Nmap, Hping, Angry IP Scanner, SuperScan
Five	OS fingerprinting	Active/passive	Nmap, Winfingerprint, P0f, Xprobe2
Six	Fingerprinting services	Active	Nmap, Telnet, FTP, Netcat
Seven	Mapping the network attack surface	Active	CartoReso, traceroute, Network Topology Mapper

Enumeration in Ethical Hacking

Enumeration is extracting a system's valid usernames, machine names, share names, directory names, and other information. It is a key component of ethical hacking and penetration testing, as it can provide attackers with a wealth of information that can be used to exploit vulnerabilities. It can also be defined as collecting detailed information about the target systems, such as operating and network infrastructure details. Enumeration can be used in both an offensive and defensive manner.

Enumeration is one of the most important steps in ethical hacking because it gives hackers the necessary information to launch an attack. For example, hackers who want to crack passwords need to know the usernames of valid users on that system. Enumerating the target system can extract this information.

Enumeration can be used to gather any of the following information:

Operating system details
Network infrastructure details
Usernames of valid users
Machine names
Share names
Directory names
Printer names
Web server details

Why Is Enumeration Important?

Enumeration lets you understand what devices are on your network, where they are located, and what services they offer. To put it simply, enumeration can be used to find security vulnerabilities within systems and networks. By conducting an enumeration scan, you can see what ports are open on devices, which ones have access to specific services, and what type of information is being transmitted. This information can then be used to exploit weaknesses and gain unauthorized access.

Carrying out an enumeration scan requires both time and patience. However, it’s a crucial step in the hacking process as it allows you to gather intelligence about your target. Enumeration can be performed manually or with automated tools. Whichever method you choose, it’s important to be thorough in your scan to maximize the amount of information you can collect.

Techniques for Enumeration

When it comes to network security, enumeration is key. By enumerating a system, you can gain a better understanding of that system and how it works. This knowledge can then be used to exploit vulnerabilities and gain access to sensitive data.

Several techniques can be used for enumeration, and your method will depend on the type of system you are targeting. The most common methods include **email IDs and usernames, default passwords, and DNS zone transfer.**

1. Using email IDs and usernames is a great way to gather information about a system. You can use this information to brute force passwords or gain access to sensitive data.

2.Default passwords are another common method of enumeration.

By using default passwords, you can gain access to systems that have not been properly configured.

3. DNS zone transfer is a technique that can be used to expose topological information. This information can be used to identify potential targets for attack.

Understanding the techniques available for enumeration can better protect your systems from attack.

Process of Enumeration

Enumeration is the process of identifying all hosts on a network. This can be done in several ways, but **active and passive scanning** is the most common method. Active scanning involves sending out requests and analyzing the responses to determine which hosts are active on the network. Passive scanning involves listening to traffic and then analyzing it to identify hosts.

Both methods have their advantages and disadvantages. Active scanning is more likely to identify all hosts on a network, but it is also more likely to cause disruptions because it generates a lot of traffic. Passive scanning is less likely to identify all hosts, but it is also less likely to cause disruptions because it does not generate any traffic.

The Types of Enumeration

There are many different types of enumeration. The most appropriate type will depend on the situation and the required information:

NetBIOS Enumeration: NetBIOS is a protocol that allows devices on a network to share resources and communicate with each other. NetBIOS enumeration is querying a device to identify what NetBIOS resources are available. This can be done using tools like **nbtstat** and **net view**.

SNMP Enumeration: SNMP is a protocol that allows devices to be managed and monitored remotely. SNMP enumeration is querying a device to identify what SNMP resources are available. This can be done using tools like **SNMP-check** and **snmpwalk**.

LDAP Enumeration: LDAP is a protocol that allows devices on a network to share information about users and resources. LDAP enumeration is querying a device to identify what LDAP resources are available. This can be done using tools like **ldapsearch** and **ldapenum**.

NTP Enumeration: NTP is a protocol that allows devices on a network to synchronize their clocks with each other. NTP enumeration is querying a device to identify what NTP resources are available. This can be done using tools like **Nmap** and **PRTG Network Monitor**.

Services and Ports to Enumerate

When conducting a penetration test or simply enumerating services on a target machine, knowing which ports are associated with it is often useful. This can be accomplished using a port scanner such as Nmap to scan for open ports on the target machine. Once you have a list of open ports, you can use a port lookup tool to determine which service runs on each port. This information can be extremely helpful when trying to identify potential attack vectors.

The following are some of the most commonly used services and their associated ports (Kulkarni, 2018):

FTP – 21
SSH – 22
HTTP – 80
HTTPS – 443
SMTP – 25
POP3 – 110
IMAP – 143
SNMP – 161

As you can see, various services can run on any given port. Knowing which service runs on which port when enumerating a target machine is helpful.

What is System Hacking in Ethical Hacking?

System hacking is the process of exploiting vulnerabilities in electronic systems for the purpose of gaining unauthorized access to those systems. Hackers use a variety of techniques and methods to access electronic systems, including phishing, social engineering, and password guessing.

Purpose of System Hacking:

Generally, the motive of the hackers behind System Hacking is gaining access to the personal data of an individual or sensitive information belonging to an organization in order to misuse the information and leak it which may cause a negative image of the organization in the minds of people, Privilege Escalation, Executing malicious applications to constantly monitor the system.

How this is carried out?

This type of hacking is generally done by a Hacker who has a lot of information regarding the System security, network, software, and how the system communicates with others in the network, often called Footprinting and Reconnaissance. Then these hackers try numerous ways to carry out the attack but the common ways are:

By deploying Viruses, Worms, Malware, Trojans

Using phishing techniques

Social Engineering

Identifying and exploiting Vulnerability

Steps:

1. **Reconnaissance:** The first step in this type of Hacking is collecting information regarding the System's infrastructure, working, system's network. This step is very important as after this step the Hacker knows what attack to perform and how to gain access without leaving a trace.

2. Scanning: This step involves scanning the target System, which includes:

- **Vulnerability Scanning:** Checking vulnerabilities in the targeted system that can be exploited to gain access.
- **Mapping of Network:** Finding the working of the network, firewalls, routers, and systems connected to it.

- **Port Scanning:** Scanning the open ports, and services running over the System/Server.

3. Gaining Access: This is the phase in which the hacker breaks into the system and gains unauthorized access to the System/Network and then elevates his privileges to that of Administrator or SuperUser so he can play with the System files that a normal/Guest user is unable to access.

4. Maintaining the Access: After the Hacker enters the System he tries to maintain the connection with it in the background until he accomplishes the goal with which he entered it.

THANK YOU